



From Policy to Practice: Leveraging OpenChain to Strengthen Open Source Governance

Wen, Ting (Wendy) | ByteDance Open Source Legal





Ting Wen (Wendy)

ByteDance Open Source Legal

I work with ByteDance's OSPO on open source compliance, governance and strategy. Before moving into the open source space, I worked as an intellectual property litigation lawyer and patent attorney in China.

Keep learning and carry on 😊



Today's Journey

- Why open source governance is challenging at scale
- How we use OpenChain as a practical framework
- Three practices from our legal–engineering collaboration
- A pain point case and what we learned, plus what's next





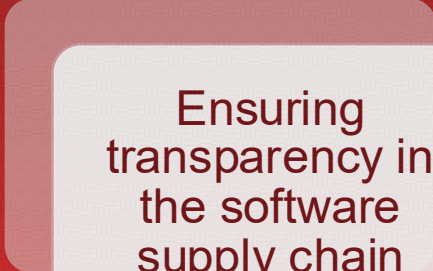
Open Source Governance Challenges at Scale



Managing
massive code
repositories and
complex
dependencies



Mitigating
compliance risks
and intellectual
property disputes



Ensuring
transparency in
the software
supply chain

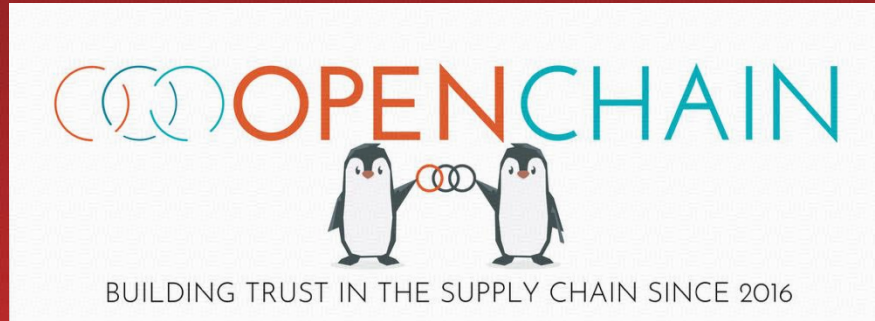


A Collaborative Approach: Legal & Engineering

- **Legal** sets clear policies, standards, and training materials
- **Engineering** builds automated systems and integrates into workflows
- **OSPO** acts as the bridge connecting rules with daily operations



OpenChain: A Governance Framework, Not a Rulebook



- Focuses on building trustworthy and verifiable compliance capabilities
- Guides "WHAT" to achieve rather than dictating "HOW" to do it
- Supports continuous improvement across different organizational stages

Three Dimensions of OpenChain Framework



Policy, Organization & Training

Clear roles and compliance awareness



Processes

Standardized operations for inbound and outbound



Tooling & Systems

Automated tools and platforms for scanning and tracking



Practice 1: Policy, Organization & Training

- Established an OSPO committee to oversee strategy and operations
- Issued comprehensive policies for consuming, contributing and releasing code
- Rolled out compliance training for all roles with relevant responsibilities





Practice 2: Embedding Compliance into Processes

- Shift-left risk detection from post-development checks into the development phase
- Built exit mechanisms for risky nested dependencies
- Standardized approval workflows for external releases and deliveries





Practice 3: Automating with Systems & Tooling

- Incremental scanning to monitor risks during active development
- Full-codebase compliance scanning prior to product releases
- Integrating build platforms to extract component data for SBOMs



Third-Party Assessment Insights



- Reached advanced capability levels in a highly complex environment
- Recognized strengths in large-scale training and tool automation



- Identified growth areas in metrics dashboards



Pain Point: Balancing Control and Velocity

Before: Blocking MRs

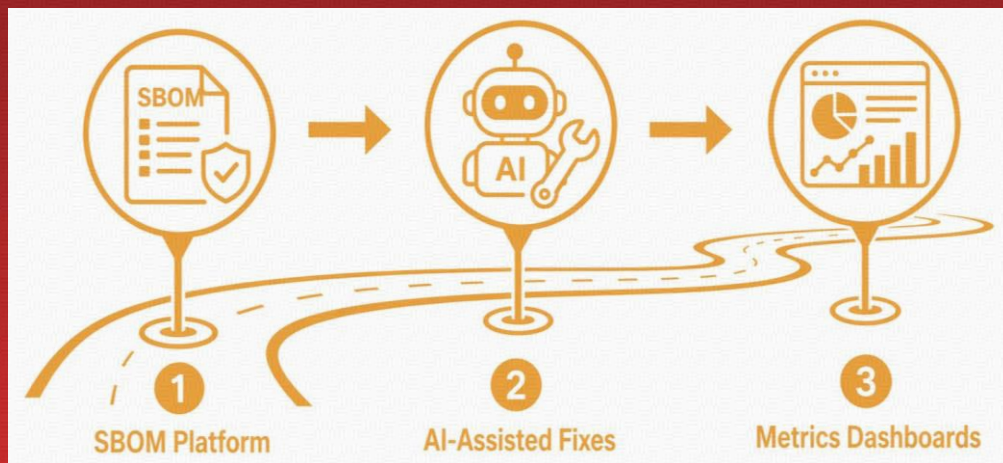
- Blocked Merge Requests upon risk detection
- False-positive due to tool accuracy, as well as usage and distribution type
- Blocked developers and slowed delivery
- Required heavy operational resources for triage

After: Non-Blocking Scans

- Incremental scans run without blocking merges
- Next-day ticketing for risk remediation
- Active metric tracking on ticket resolution
- Pre-release full scans as safety net



Next Steps: Scaling the Governance Ecosystem



- **SBOM Platform:** End-to-end automation for delivery and regulation requirements
- **AI-Assisted Fixes:** Using AI to suggest and apply compliance remedies
- **Metrics:** Driving improvements through data dashboards